nestself



CMS and employee experience strategy

How NestSelf publishes reviewed content, how employees find and use it, and how polls, requests and general questions reach an outcome. An overview for review; the engineering reference carries every detail.

Version 1.0
24 October 2026

Status
Draft for founder review

Engineering reference
docs/tasks/cms-ee/cms-ee-strategy.md

OVERVIEW

What this strategy decides

Fourteen of the thirty-two decisions carry the design. Each has a numbered entry, with conditions and alternatives, in the engineering reference.

A small content system inside the platform we already run. Every resource in all four languages. One availability rule decides what every employee sees, everywhere. Original employee text never enters the CMS.

C-02 **A thin CMS inside the NestSelf API and admin, no headless CMS**
One sign-in, one grant model, one audit log. A second system would need its own access rules.

C-03 **Tiptap in the admin; content stored as validated structured blocks**
Editors cannot insert HTML or scripts. Employees' screens render the blocks with NestSelf components, never raw HTML.

C-06 **Approval binds one exact revision**
A fingerprint covers text, media, links, call to action and audience. Any change after approval needs review again.

C-07 **One shared catalogue; clients see it through audiences**
No copies per client. Personal state (saved items, votes, requests) is per employer and isolated by row-level security.

C-08 **Author, reviewer and publisher are separate grants**
The existing content actions are reused; review moves out of the publisher template. Nobody approves their own work.

C-10 **One availability decision for every read path**
Home, lists, search counts, detail, saved items and media all ask the same question, so they cannot disagree or leak.

C-11 **Client capabilities come from configuration, never from copy** founder: per client
Library, general questions and event interest are switched on per client. Editors cannot promise a service.

C-14 **Private media, scanned, re-checked on every request**
No public file links. Revoking access works for the next byte range, not the next day.

C-15 **Search in PostgreSQL, Serbian and Hungarian aware**
Both stemmers ship with PostgreSQL. Cyrillic and Latin fold to one form. Counts and snippets only cover what the reader may see.

C-17 **General questions live in the confidential domain**
The confidential domain's own access paths: the asker, the professional who claimed it, or approved emergency access. Nobody else, whatever their role.

C-19 **Poll votes are pseudonymous and never shown in small groups**
One current answer per person per poll; ten distinct participants before any distribution appears.

C-20 **Requests are tracked to an outcome; editors see a sanitized brief**
Owners, due dates on a business calendar, and no raw employee text or identity in the editorial queue.

C-22 **The employee context names its employer**
A person with two employers has two separate sets of saved items, votes and requests. Switching clears every cached screen.

C-27 **Employees and professionals use the workspace app; staff use the admin**
Professionals are not staff. Their question queue sits beside the employee workspace, as the auth strategy places it.

SCOPE

The loop the first version closes

Epic NS-CONTENT-01, version 1.0 of 22 October 2026. Its backlog is the acceptance contract.

Find a relevant topic
By need, category or everyday words, in the reader's language.

Get practical help
Short articles, audio and video with transcripts, checklists, answered questions.

Save or try something
Saved items and the last position stay private to this employer context.

Ask or suggest
A general question to a professional, or a topic, format or translation request.

See what happened
A private answer, a published resource, or a reasoned closure, with status on the way.

In the first version

- Admin authoring, professional review, scheduling, withdrawal
- Six categories, six resource types, collections, Home curation
- Media with rights and expiry, delivered only to its audience
- Home, Explore, search, detail, saved items, preferences
- Usefulness feedback and interest polls
- Editorial requests with owners, due dates and outcomes
- General questions answered by assigned professionals
- Neutral notifications, privacy-safe aggregates, retention

Deliberately not in it

- Native mobile screens (the API is ready for them)
- Event registration, consultations, budgets, team offers
- A page builder, an open forum, peer answers, comments
- AI advice or recommendations from sensitive history
- Wellbeing scores or any diagnosis-like question
- HR editing professional content, named usage reports
- Public marketing CMS delivery

RELEASE LEVELS

M1
First vertical slice
An admin publishes an article with an image; an invited employee reads and saves it.

Drafts and other clients' content denied, including the image.

V1
Complete epic
Full workflow, search, all formats, collections, polls, requests, moderated questions.

The fifteen-step acceptance scenario passes; queues have owners.

V1.1
After the pilot
HR featuring proposals, more content languages, bulk editing.

A stable pilot and a demonstrated need.

LATER
Separate epics
Events, consultations, budgets, programs, wellbeing measurement, community.

Each with its own access and operational rules.

STARTING POINT

What exists, and what the epic assumed

The epic was written before the code was reviewed. These corrections come from the repository on 24 October 2026.

Topic	The epic assumed	The strategy uses
Data layer	PostgreSQL with Prisma	Drizzle with row-level security, as the auth strategy decided (D-37)
Content permissions	New actions such as `content.create`	Eleven `content.*` actions already exist and are reused; sixteen new actions cover taxonomy, media, polls, requests and intake
Templates	Author, publisher, intake expert	Existing author and publisher templates change; reviewer, editorial lead, intake professional and intake lead are added
Routes	`/api/employee`, `/api/admin`, `/api/intake`	The auth strategy's prefixes: `/api/library`, `/api/me`, `/api/expert/intake`, `/api/ops/cms`, `/api/orgs/:orgId`
Employer context	"Personal context of the active organization"	The personal context had no organization; it now names one, and personal state is kept per employer
Client caches	Cleared on organization switch	The web apps kept old queries on switch; the fix ships in M1 with a test
Restricted intake	A new module	The confidential-domain module the auth strategy reserved (T-2.4), with its four access paths

Ready to build on

Sessions, the decision engine with its golden table, default-deny routes, audit, row-level security, BullMQ jobs, SES mail, two seeded clients.

Missing and planned here

Editor, content schema, media storage and delivery, search, outbox, idempotency handling, notifications, reporting.

Retired

The flat `content_items` table and its sample screens. Legacy team polls and channels stay until the auth track retires them.

Depends on the authentication track

Operations routes for assigned clients (T-2.0), grant administration (T-2.1) before the pilot, and step-up enforcement (T-2.6) before questions open. If step-up is not delivered in time, this epic implements its restricted branch.

ARCHITECTURE

Modules and what each one owns

New NestJS modules in the existing API. No new runtime, identity system or database.

SURFACES

Workspace web
Employees: Home, Explore, Saved, My requests. Professionals: Questions

Admin web
Staff: editor, review, publishing, taxonomy, media, demand, polls

Workspace, organization context
HR: monthly suppressed summary only

API MODULES

cms
Resources, revisions, review, publications, taxonomy, collections, Home slots

media
Uploads, scanning, renditions, rights, protected delivery

library
Availability, Home, discovery, search, detail, saved items, events

engagement
Polls, votes, feedback, pseudonyms

editorial
Requests, timelines, briefs, business clock

professional
Intake queues, questions, private replies, publication permission

notifications
Outbox, in-app notices, neutral email

reporting
Suppression, metrics, employer summary

SHARED FOUNDATION (EXISTS)

Sessions and guards
Cookie sessions, CSRF, default deny

authorize()
Grants, assignments, confidential hard deny

PostgreSQL 17
Drizzle, row-level security, audit

Valkey and BullMQ
Caches, scheduled and queued jobs

The professional module is walled off

Only its own code may import its tables; a lint rule and a response-scanning test enforce that no CMS, editorial, reporting or HR response carries an intake field.

State changes and events commit together

A transactional outbox carries ids, never text. Workers deliver notifications and index updates once, retry on failure and show what failed to an owner.

Route prefix	Context	Used for
`/api/library`, `/api/me`	Personal, per employer	Catalogue reads, media, search; saved items, preferences, requests, questions, notifications
`/api/expert/intake`	Expert	Queues, claims, replies, permission requests
`/api/ops/cms`	Operations, web session	Editing, review, publishing, taxonomy, media, demand, polls, performance
`/api/orgs/:orgId`	Organization	The monthly employer summary

A new shared package, `@nestself/content`, holds the block schema and validation (used by the API), the Tiptap editor (admin only) and the renderer (admin preview and workspace), so all three agree on one format.

CONTENT

From draft to publication

One resource, one variant per language, immutable revisions, and publications that point at one approved revision.

Four records

Resource: the language-independent item (article, video, audio, practical resource, Q&A or collection) with its primary category and owner.

Variant: one language version with its own review.

Revision: a frozen snapshot once submitted; the one working draft autosaves and refuses to overwrite a newer change.

Publication: the approved revision, its audience and its time window.

1. **Author drafts**
   Type, language, category, the promise to the reader ("what you get"), duration, sources, media and a proposed audience. Validation lists what is missing.
2. **Preview in the real layout**
   The employee renderer at phone and desktop widths, for a simulated client and team; no real employee's state is loaded.
3. **Submit one revision for review**
   A reviewer qualified for the discipline approves or returns it with comments. Authors and last editors cannot review their own revision.
4. **Publish now or schedule**
   The publisher confirms the audience, which may narrow the approved one but never widen it. Only the approved fingerprint can go live.
5. **Maintain**
   Review dates, rights expiry and collection minimums create tasks for an owner and a backup. Urgent withdrawal removes the item everywhere at once.

STATES

Revision	`draft` → `in_review` → `changes_requested` or `approved` → `superseded`
Publication	`scheduled` → `live` → `expired` , or `withdrawn` at any time
Media asset	`uploaded` → `quarantined` → `processing` → `ready` , or `rejected` ; `expired` when rights end

> **Editing live content never shows half-reviewed text**
> Employees keep seeing the previous approved revision until the new one is approved and its publication starts. Starting a publication never waits for a background job: availability is computed from the stored times on every read.

PERMISSIONS

Who may do what

Templates are starting sets of grants, not roles. One person may hold several, but never review their own work.

Template	Scope	Main actions	Notes
Content author changed	Assigned categories	`content.write`, `content.submit`, `content.preview`, `media.upload`	Cannot review or publish
Content reviewer new	Assigned categories	`content.review`, `content.preview`	Limited to approved disciplines: psychological, legal, financial, health, nutrition, general
Content publisher changed	Assigned categories	`content.publish`, `content.schedule`, `content.restrict`, `content.archive`, `content.preview`	Review removed from this template
Editorial lead new	Platform	`taxonomy.manage`, `home.manage`, `media.manage`, `poll.manage`, request and brief management, metrics	Never reads raw employee text
Intake professional new	Assigned queues	`intake.queue.view`, `intake.claim`	Reads a question only after claiming it
Intake lead new	Assigned queues	`intake.queue.view`, `intake.reassign`	Reassignment removes the previous reader at once
Expert changed	Assigned cases	`conversation.read.assigned`, `intake.respond`, `intake.permission.request`	Only through the claim's case assignment
Employee changed	Own, per employer	`content.read`, `content.bookmark`, `feedback.submit`, `poll.respond`, `editorial.request.submit`, `conversation.participate`	Sees only available content of the active employer
HR administrator	Organization	`reports.aggregate.read`	Monthly summary above the threshold; no names, no text

Editorial scope is the primary category

The auth strategy's "assigned collections" scope is mapped to categories: an author assigned to Sleep and rest edits resources whose primary category is Sleep and rest. Lists are filtered to the categories a person holds the action for.

No administrator key to private questions

Platform, organization and category grants are refused by the decision engine for confidential records. A known record id gives an admin, HR or CMS account nothing.

ACCESS

One rule decides what an employee sees

One implementation, composed by every read path, proven by a golden table of twenty-two cases against PostgreSQL.

A publication is available only when every one of these holds. Audience rows combine with OR; everything else is AND.

Active person
Not suspended or deactivated

Valid employer context
An active, current membership in the named organization

Active resource
Not archived

Published and current
Started, not ended, not withdrawn, the latest for its language

Audience matches
All clients, this organization, or this team and its parents

Capability enabled
The client has the capability the publication requires

Media valid
Every referenced file processed, scanned and within its rights

The reader's language
Always the interface language; Cyrillic is generated from the approved Latin text

Collections cannot widen
A collection never makes a hidden child visible

READ PATHS THAT USE IT

Home · Explore and categories · Collections · Search results, counts, facets, snippets · Content detail · Saved items · Related links and calls to action · Media files, every byte range · Poll placement · Admin preview (simulated)

Unavailable means not found

An employee who may not see an item gets a 404, not a refusal that confirms it exists. A saved item that was withdrawn shows a neutral "no longer available".

Two employers, two worlds

Saved items, history, votes and requests belong to one employer context. Switching employer clears every cached screen before the new one loads.

EMPLOYEES

Home, Explore, Saved, My requests

Built mobile first in the workspace app. No mood questions, no streaks, no view counts.

HOME, IN THIS ORDER, EMPTY MODULES OMITTED

1. **Greeting and search**, with the current employer visible
2. **One featured item** with its outcome and duration
3. **Quick needs**: "A calmer end to the day", "Better sleep"
4. **Under five minutes**: three or four formats
5. **Saved and continue**, when private state exists
6. **Explore topics**: the six starter categories
7. **Collection of the month**, curated
8. **Ask a professional**: one approved answer
9. **Shape future topics**: at most one poll
10. **Additional support**: only what really works

Search in everyday language

Serbian Latin or Cyrillic, with or without diacritics, Hungarian, English; results always in the reader's language. Synonyms such as "I cannot switch off". Typing errors fall back to similarity matching. Raw search text is never stored.

Detail that works on a phone

Outcome, duration, author and reviewer with the review date, practical steps, transcripts and captions. Video never starts with sound. "Was this useful?" and one allowed next step.

Private by default

Up to three interests, optional and editable. Continuation history can be switched off, which deletes it. Nothing here infers a health condition.

REQUIRED STATES, EACH WITH TRANSLATED COPY AND A TEST

Loading	Skeleton and an announcement; the previous employer's content disappears at once	**Language switch**	Every screen reloads in the new language; nothing stays in the old one
Saved item withdrawn	"This content is no longer available", with a replacement only if the reader may see it	**Media failure**	Retry, transcript, and a report that carries only a safe error code
No results	Related topics and "Suggest content"; nothing is sent until the employee confirms	**Session expired**	Sign in again and return; form text is never put in the address

MEDIA

Files that only reach their audience

Local storage in development, a private S3 bucket in staging and production, both behind the same interface.

UPLOAD Staff stream a file through the API into a private quarantine area. Size is capped per kind before anything is read.

CHECK The real file type is read from its bytes; the malware verdict comes from GuardDuty in AWS. SVG, HTML and executables are refused.

PROCESS Metadata such as GPS is stripped; images get phone and desktop renditions; audio and video are probed for length and rewritten for streaming.

APPROVE Rights, licence, consent and alternative text sit on the asset. A revision with an unready or expired file cannot be submitted or published.

DELIVER Every request, including every byte range of a video, re-checks the reader's access. No public links, no shared caches.

Kind	Accepted	Size limit	Length limit	Delivered as
Image	JPEG, PNG, WebP	15 MB	n/a	WebP and JPEG renditions with focal point
Audio	MP3, M4A	100 MB	30 min	Streamed with seeking; transcript in the text
Video	MP4 (H.264, AAC)	300 MB	10 min	Streamed with seeking; captions and transcript
Captions	WebVTT	512 KB	n/a	Caption track, on by default when available
PDF	PDF, optional extra only	20 MB	n/a	A download in a sandbox; never the only format

What revocation can and cannot do

New requests are refused the moment access ends. Bytes already downloaded, or a PDF saved by the reader, cannot be recalled; the product copy never promises otherwise. Faster signed delivery is a later decision with its own revocation window.

ENGAGEMENT

Polls, feedback and requests

Each signal has an owner and an outcome the employee can see.

Interest polls

- One question, two to five options and "none of these"; open seven to fourteen days
- Topic interest or format preference only; never a health question
- One current answer per person, changeable until close; no history kept
- Eligibility fixed at opening; new members join the next poll
- At most one poll per person per week; a skipped poll stays away
- Closing records a decision and, where possible, links what was published

What the employee is told

"Participation is optional. Your employer cannot see your individual response. NestSelf uses responses for aggregate content planning." The word anonymous is never used: votes are pseudonymous, keyed per poll with a secret the editors do not hold.

Editorial requests

Suggest a topic, another format or a translation, register interest in an event topic, or report a problem with a resource. Structured choices are enough to submit.

Received	Triage within 2 business days
Waiting for you	One reminder after 7 days; closed after 14 without reply
Reviewing, planned, preparing	An owner, a next action and a due date at every step
Available	A link the sender can actually open
Closed with an explanation	A reason, and an alternative where one exists

Editors work from a brief

Any free text the employee adds goes to the confidential domain; a professional turns it into a sanitized brief. Editors never see who asked or what they wrote.

10
distinct participants before any distribution appears, internally or to an employer

5
business days for a decision or meaningful update, on the Belgrade calendar with holidays

3
answers to "Was this useful?": yes, partly, no, with a predefined reason

QUESTIONS

A general question reaches one professional

Professional answers to general educational questions. Not therapy, not a chat, not an emergency channel.

WHO CAN OPEN THE ORIGINAL QUESTION

The employee who asked
Their question, clarifications and the approved reply

The professional who claimed it
Through the case assignment the claim creates; gone when reassigned

Time-limited emergency access
Separately approved and logged, from the auth strategy

Everyone else
Platform owner, CMS staff, client success, HR, managers: refused in code, even with the id

1. **Ask**
   Subject, language and up to 1,500 characters. No attachments. The form says who reads it, that the employer does not, and where urgent help is.
2. **Claim**
   Queues per discipline show only safe details. Claiming is atomic and creates the read path; the first read needs a fresh sign-in.
3. **Clarify, at most twice**
   One clear question per round, so the flow never becomes an unpromised chat.
4. **Answer**
   Private, attributed and dated, reviewed by a second professional where the subject requires it.
5. **Maybe publish a generalized version**
   Only with the employee's yes to the exact text. Declining changes nothing about their answer.

Before claiming

The queue shows the discipline, language, waiting time in business hours, due date and clarification round. Never the question, never the asker's name, never the employer's name.

After claiming

The professional reads the question and replies privately. Every read is audited without copying the text. If the claim sits idle for two business days, it returns to the queue and the former reader loses access.

1,500
characters per question; no attachments

2
clarification rounds at most

5
business days target for the first answer

0
emergency numbers hard-coded; the help block is a maintained, reviewed item

The form stays closed until the queue is staffed

Each discipline needs a named owner and backup with weekly capacity before questions open (founder decision F-C03). Until then the screen explains honestly what is available instead.

PRIVACY

Who sees what, and for how long

Periods are configurable and pending legal review; the code reads them from the retention table.

Information	Employee	CMS staff	Assigned professional	HR and managers
Published resource	if available	in scope	as a reader	as a reader
Drafts and reviews	no	by grant	review only	no
Saved items and history	own	no	no	no
Question or request free text	own	no	claimed only	no
Sanitized brief	outcome	assigned	as needed	no
Individual poll choice	own	no	no	no
Aggregates	decisions	suppressed	no	monthly, k = 10

Data	Proposed retention
Archived revisions	24 months
Saved items	Until removed; 30 days after membership ends
Continuation history	90 days of inactivity; off deletes it
Individual poll answers	90 days after the poll closes
Question and note text	90 days after closure
Request metadata	12 months; one setting, changed without a deploy
Usage events	90 days; monthly aggregates 12 months

Not in logs, not in links

Search text, questions, answers, poll choices and notes are redacted from logs, error reports, audit details, event payloads and URLs, and a test proves it.

Neutral messages

Email says "You have a new update in NestSelf" and links to a screen that checks access again. No topic, no question text.

No tracking

No advertising pixels, session replay or input recording. Usage events are day-level and pseudonymous.

DELIVERY

Four milestones and a pilot week

Two engineers with parallel agents. About ten calendar weeks, one more than the epic estimated.

WEEKS 1–3

M1 First vertical slice

- Dependencies and the editor spike first
- Employer context and cache fix
- Actions, templates, category scope
- Core tables and migration
- Block schema, renderer, minimal editor
- Images, availability, detail, saved

Exit Admin publishes; Employee A reads and saves; Employee B is refused, image included.

WEEKS 4–5

M2 A usable library

- Review, scheduling, withdrawal
- Taxonomy, collections, Home slots
- Search in both scripts
- Audio, video, captions, S3
- Languages and preferences

Exit A live revision stays live while its successor is reviewed; phones and languages work.

WEEKS 6–7

M3 Feedback and requests

- Feedback and interest polls
- Suppression service
- Confidential module skeleton
- Requests, calendar, queues
- Notifications and recovery

Exit A poll reaches a decision; one request is fulfilled, another closed with a reason.

WEEKS 8–9

M4 Questions and controls

- General questions and claims
- Step-up on first read
- Publication permission
- Metrics and employer summary
- Retention and freshness tasks

Exit A professional answer with no admin or HR read path; the full scenario passes.

WEEK 10

Pilot preparation

- Performance and accessibility checks
- Runbooks and owners
- Starter content and staffed queues

Exit Evidence of readiness for real employees, not an empty library.

15
steps in the acceptance scenario, run end to end in Playwright and in staging

22
availability golden cases, plus thirty new decision-engine cases

500
milliseconds P95 target for list and detail at 100 sessions, to be measured

Why ten weeks

The epic's two-week first slice assumed an editor, a media path and a content schema already existed. None do, so M1 takes three weeks on its critical path. The remaining milestones keep the epic's two-week rhythm.

NEXT

Decisions taken, and what remains

The founder answered the open product questions on 24 October 2026. Legal review remains before real employees use the library.

Every resource in all four languages — decided

Readers always see their chosen language. Serbian Latin, Hungarian and English are written and reviewed; Cyrillic is generated from the approved Latin text, as the interface already is.

Effect: a resource publishes only when all three are approved; writing and review effort roughly triples.

Questions open only when staffed — accepted

Each discipline needs a named owner and backup with weekly capacity.

Effect: the question form explains what is available until then.

Request metadata kept 12 months — decided

The value is one setting in the retention table.

Effect: a command changes it without a deployment, and the change is audited.

Library on for every client — accepted

General questions and event interest stay off per client until they are staffed.

Effect: client success switches them on later.

Schedule — assumed

About ten calendar weeks to a pilot-ready V1, one more than the epic's estimate.

Default: keep V1 scope; accept the extra week.

Content capacity — needed

Serbian, Hungarian and English writers and professional reviewers for about forty starter resources.

Needed by: M2, when the library opens to the first synthetic pilot.

FOR LEGAL COUNSEL AND THE DPO

L-C01	Can a general educational question ever count as health documentation in Serbia or Hungary? Default: no; a record that becomes a professional case is reclassified.
L-C02	Lawful basis and notice text for pseudonymous votes, feedback and usage events, which remain personal data under GDPR.
L-C03	Licence and consent records for stock, generated and commissioned media, and consent withdrawal.
L-C04, L-C05	The retention periods, and the threshold of ten for employer summaries.